

Ola 3C Tokens

Tokens read-only con alcance, expiracion y revocacion

Fecha base: 2026-05-07

Fuente: 17-ola-3c-tokens-integracion-gobernados.md

Documento generado para ejecutar el piloto de P&Pmis Ai SaaS como plataforma colaborativa en linea de Project Controls, con trazabilidad por roles, workflows, Cost Manager, AWP, contratos, claims y readiness.

Contenido

- Objetivo
- Alcance Cerrado En Esta Iteracion
- Endpoints De Gestion
- Uso De Token
- Controles De Seguridad
- Gate Operativo
- Politica De Operacion
- Checklist De Cierre
- Siguiente Ola Recomendada
- Decision

Fecha base: 2026-05-07

Objetivo

Permitir que consumidores externos controlados descarguen manifiestos, exportaciones y paquetes de integracion sin usar credenciales personales ni abrir escritura hacia sistemas externos. Esta ola crea tokens de integracion con alcance por proyecto, datasets, formatos y expiracion.

Alcance Cerrado En Esta Iteracion

- Tabla integration_tokens con token hashado, prefijo publico, datasets, formatos, estado y expiration.
- Endpoint GET /api/v1/projects/{project_id}/integration-tokens.
- Endpoint POST /api/v1/projects/{project_id}/integration-tokens.
- Endpoint POST /api/v1/projects/{project_id}/integration-tokens/{token_id}/revoke.
- Tokens con prefijo pypmis_it_.
- El secreto del token solo se muestra una vez al crearlo.
- Tokens validos solo para:
 - integration-manifest
 - integration-export
 - integration-package
- Alcance por dataset.
- Alcance por formato json, csv, both o xlsx.
- Expiracion maxima de 90 dias.
- Revocacion inmediata.
- El token hereda la membresia y confidencialidad documental del usuario que lo creo.
- Gate tools/pilot_integration_gate.ps1 actualizado para crear, usar, limitar y revocar tokens.

Endpoints De Gestion

Listar tokens:

```
GET /api/v1/projects/{project_id}/integration-tokens
Authorization: Bearer <jwt_usuario>
```

Crear token:

```
POST /api/v1/projects/{project_id}/integration-tokens
Authorization: Bearer <jwt_usuario>
Content-Type: application/json

{
  "name": "BI weekly export",
  "datasets": ["cost_sheet", "funding_sources", "cash_flow"],
  "formats": ["json", "csv", "both", "xlsx"],
  "expires_in_days": 30
}
```

Revocar token:

```
POST /api/v1/projects/{project_id}/integration-tokens/{token_id}/revoke
Authorization: Bearer <jwt_usuario>
```

Solo roles con can_configure pueden gestionar tokens.

Uso De Token

Una vez creado, usar el valor devuelto en token como Bearer:

```
$headers = @{ Authorization = "Bearer pypmis_it_XXXXXXX_<secreto>" }  
Invoke-RestMethod -Uri "http://localhost:8000/api/v1/projects/1/integration-manifest" -Headers  
$headers  
Invoke-WebRequest -Uri "http://localhost:8000/api/v1/projects/1/integration-  
package?datasets=cost_sheet,documents&format=both" -Headers $headers -OutFile ".\package.zip"
```

Si el token intenta acceder a un dataset fuera de alcance, responde 403.

Si el token esta vencido o revocado, responde 401.

Controles De Seguridad

- El token se guarda como SHA-256, nunca en claro.
- El prefijo publico permite identificar el token sin exponer el secreto.
- La expiracion maxima es 90 dias.
- El token no sirve para endpoints transaccionales.
- El token no puede crear, modificar, aprobar ni borrar informacion.
- El token respeta la membresia actual del usuario creador.
- Si el usuario creador pierde membresia, el token deja de poder operar ese proyecto.
- Los documentos y adjuntos siguen filtrados por confidencialidad.

Gate Operativo

Ejecutar:

```
powershell -ExecutionPolicy Bypass -File .\tools\pilot_integration_gate.ps1
```

El gate valida:

- La cadena previa de readiness, seguridad e integraciones.
- Creacion de token con cost_sheet y documents.
- Uso del token para manifiesto.
- Uso del token para paquete ZIP.
- Bloqueo de funding_sources por estar fuera de alcance.
- Listado del token por administrador.
- Revocacion del token.
- Rechazo 401 despues de revocar.

Politica De Operacion

- Crear tokens por consumidor, no tokens compartidos para toda la organizacion.
- Usar expiraciones cortas durante piloto, idealmente 7 a 30 dias.
- Dar solo los datasets requeridos.
- Revocar tokens al terminar cada prueba de integracion.
- No enviar tokens por canales no controlados.
- Para produccion, combinar esta base con OIDC/MFA y rotacion formal.

Checklist De Cierre

```
docker compose build api
docker compose up -d api
docker compose exec -T api pytest
docker compose exec -T frontend npm run build
powershell -ExecutionPolicy Bypass -File .\tools\pilot_integration_gate.ps1
powershell -ExecutionPolicy Bypass -File .\tools\pilot_check.ps1
```

Siguiente Ola Recomendada

La siguiente ola puede preparar consumo ejecutivo y validacion manual:

- Plantillas XLSX generadas desde los paquetes de integracion.
- Catalogo de paquetes descargados si el cliente exige auditoria.
- Rotacion automatica y alertas de tokens proximos a vencer.
- Staging de importacion XER/XML con comparacion antes/despues.

Decision

Con Ola 3C el piloto ya puede entregar integraciones gobernadas con tokens de solo lectura, alcance minimo y revocacion. Esto robustece pruebas con BI, ERP staging o terceros sin comprometer el login normal ni abrir escritura hacia fuera.